國立高雄大學　Term Project I

資安文件搜尋引擎

開發過程、搜尋實驗與現場操作

主講約 17 分半　另有 5 分鐘 Demo

專題要求

老師要我們做一個小型主題搜尋引擎

收集資料	5–10 個起始網址，收集 200–1,000 個有效公開頁面。
建立搜尋	自寫倒排索引，用 TF-IDF cosine 排序，由 Flask 顯示。
驗證品質	固定 10 題，按全文判前五筆相關性，分析至少兩道弱題。

要做資安工具，還是做一個找資安工具的搜尋引擎？

最初的構想是自主滲透 Agent 和 Kali 指令。

把資安構想收斂成可搜尋的文件

自主執行操作

系統接手執行資安流程，重點落在工具的操作結果。

搜尋技術文件

回傳可閱讀、可引用的工具或操作文件，能按原文判斷相關性。

最後採用

選技術文件搜尋，從 Kali、Nmap、Metasploit 起步。

網頁先收下來，查詢時再現算排名

上網爬取	起始網址 → 公開網頁 → 正文與來源存到本機
本機建索引	文件前處理 → 倒排索引 → 存檔
即時搜尋	關鍵字 → 從索引找候選 → 排序並顯示結果

課程展示語料　7 站、980 頁

搜尋 SQL injection 工具，sqlmap 卻排不進前五

有些頁面出現了關鍵字，實際用途卻差很遠。

固定標題加分與 BM25 比較

固定加分

標題每命中一個查詢詞，固定加 0.5。

BM25

限制重複用詞帶來的加分，並調整文件長度的影響。

最後採用

撤回固定加分，BM25 留作對照。

同一道題，排名往兩個方向走

原始 TF-IDF	sqlmap 排在前五之外。
固定標題加分	談 DLL injection 的頁面升到第 1。
改用 BM25	sqlmap 升到第 1。

Java 反編譯器為什麼出現在 SQL 工具的前五名？

jd-gui 的頁尾廣告提到 SQL injection。

先清正文，再把詞形處理一致

只清網站樣板

從建索引用的正文移除可辨認的廣告與導覽。

只統一詞形

查詢和文件都把 scanning 還原成 scan。

一起使用

把兩項處理分開測，再測合併效果。

最後採用

採用正文清理與詞形統一，仍用 TF-IDF cosine 排序。

清完廣告，sqlmap 補進前五

第 5 → 前五外

jd-gui 移除頁尾廣告後

前五外 → 第 5

sqlmap 補上原本的位置

早期固定語料，比較只改樣板清理的前後名次。

片語可以查了，
為什麼普通搜尋反而變慢？

加入詞的位置後，索引變大，一般查詢也多了處理成本。

讓位置資料只在需要時解碼

查原文驗證片語

保留較簡單的索引，片語查詢時回頭逐篇檢查。

保留位置索引

壓縮位置與字元座標。只在查片語或要顯示證據時讀必要資料。

最後採用

保留位置索引，加上壓縮與按需解碼。

片語變快，索引再壓小

49.0 → 4.4

毫秒｜片語加排除
採用位置索引後

47.9 → 9.8

MB｜索引檔案
壓縮前後

分開量測。加入位置與字元座標時，一般查詢從 0.36 增至 3.03 毫秒。

找到寫檔範例後，怎麼知道它真的會附加？

「站外、sudo、附加」三個條件，都要在答案裡成立。

補進文件後，再用同一份資料比排序

沿用舊排序

檢查光是把三篇文件放進索引會發生什麼。

只排除指定站

排除 GTFOBins，再看站外答案的名次。

加同例證據

核對同一個範例的寫入權限與附加效果。

最後採用

採用來源排除與效果證據排序，留在 v8.6 實驗模式。

三篇答案排到第 1、2、3 名

文件	舊排序	只排除 GTFOBins	加入同例證據
Debian hosts	26	22	1
Ubuntu vsftpd	347	245	2
Ubuntu Apache2	549	447	3

同一查詢、同一份 986 頁索引。表格數字為排名。

整體評估

前五筆，有幾筆真的回答了問題？

$$3 \div 5 = 0.60$$

Precision@5　前五筆中有 3 筆相關

固定查詢、固定語料。比較兩版時，使用同一份相關性判定。

整體評估

課程題與保留題的排序比較

固定題組	課程基準 TF-IDF	比較模型 BM25
課程題　10 題	0.40	0.80
保留題　24 題	0.40	0.625

980 頁語料 | 平均 P@5 | 同一題組共用模型判定，待人工確認。

整體評估

v8.6 在 12 道新題上的結果

0.1833 → 0.6333

平均 P@5 | v8.5 對 v8.6
8 題進步、4 題持平

2.56 → 2.98

毫秒 | 暖查詢中位數
計時使用 14 題，含兩道已知弱題

兩版都使用 986 頁。相關性採模型判定，助理按原文與手冊複核。

目前仍有兩種題找不到答案

跨站比較	同時要求 Ubuntu 與 GTFOBins 的比較題，P@5 仍為 0。
站外 SUID 附加	補進的站外例子支持 sudo，SUID 附加題仍為 0。
提交前	課程評估需人工確認，組員另交個人心得。

現場操作

5 分鐘 Demo

課程基準搜尋 → 同題切換 v8.5／v8.6 → 無結果查詢

http://127.0.0.1:5057/

早期排序實驗與去留

試過的改動	當時的觀察	去留
固定標題加分	早期同批 P@5 為 0.96 → 0.80	撤回
同義詞擴展	aircrack-ng 進前二，sqlmap 由 1 到 4	選用
清樣板與詞形	早期同批 P@5 為 0.42 → 0.54	課程基準
長度調整	v7.1 只調長度 0.84，加命中優先後 0.80	兩項皆可選用

每列只比較該輪共用的語料與標註。

課程十題逐題結果

題目（簡稱）	TF-IDF	BM25
wifi 密碼破解	0.4	0.8
SQL injection 工具	0.2	0.6
連接埠掃描	0.4	0.8
攔截 HTTPS	0.2	1.0
網頁弱點掃描	0.6	0.6
封包分析	0.8	1.0
執行 Metasploit 模組	0.0	0.6
APK 反編譯	0.6	0.8
伺服器目錄列舉	0.4	0.8
反向 shell 酬載	0.4	1.0

980 頁固定語料 | 模型判定 P@5

實際爬取紀錄

1,027

次 HTTP 請求

980

個有效公開頁面

7

個白名單站點

v8.1 另存重爬快照。有效頁數相同，仍與課程展示快照分開保存。

v8.6 網站操作畫面


IR Lab
搜尋
v8.6 實驗
評估
寫入效果搜尋
在相同語料上比較 v8.5 與 v8.6，查看附加、覆寫和刪除的原文證據。
986
outside GTFOBins append to a local file with sudo
搜尋
搜尋結果 10
2.4 ms
切換至 v8.5 對照
操作 append 權限 sudo 排除 GTFOBins 3 筆有同例證據
01
https://wiki.debian.org/BootstrapBootableSystem
2.0828
BootstrapBootableSystem - Debian Wiki
echo "127.0.1.1 $(cat ${debstrapFolder}/etc/hostname)" | sudo tee -a
"${debstrapFolder}/etc/hosts"
... replace Systemd-coupled ones from Debian. Create or edit basic config files /etc/fstab mmdebstrap creates just an empty stub, so you need to list the rootFS and any subvolumes manually, including the ESP at /boot/efi . See fstab for details. /etc/hostname Put a hostname of your choice into this file, for example: echo my-new-laptop | sudo tee "${debstrapFolder}/etc/hostname" /etc/hosts mmdebstrap creates entries necessary for basic networking, so just add an entry for the hostname chosen above: echo "127.0.1.1 $(cat ${debstrapFolder}/etc/hostname)" | sudo ...